

OWASP Juice Shop Vulnerability Assessment Report

Web Application Penetration Testing & Vulnerability Assessment

Introduction

This report presents the results of a web application penetration testing assessment performed on OWASP Juice Shop in a controlled lab environment using Kali Linux and Burp Suite Community Edition. The assessment focused on identifying common web application vulnerabilities based on OWASP Top 10 security risks.

Objective

The objective of this assessment was to identify, analyze, and document security vulnerabilities within OWASP Juice Shop using practical penetration testing techniques and HTTP traffic analysis.

Tools Used

- Kali Linux
- Burp Suite Community Edition
- Firefox Browser
- OWASP Juice Shop
- Podman Container Engine

Methodology

1. Configured Burp Suite proxy interception.
2. Intercepted and analyzed HTTP requests/responses.
3. Tested authentication mechanisms using SQL Injection payloads.
4. Performed Cross-Site Scripting testing using malicious payloads.
5. Analyzed server responses and security headers.
6. Documented identified vulnerabilities and mitigation recommendations.

1. SQL Injection

Severity: High

Description: A SQL Injection vulnerability was identified in the login functionality of OWASP Juice Shop. Authentication bypass was achieved by injecting malicious SQL payloads into the login request.

Impact: Attackers may bypass authentication and gain unauthorized access to user accounts.

Recommendation: Use parameterized queries and validate user input properly.

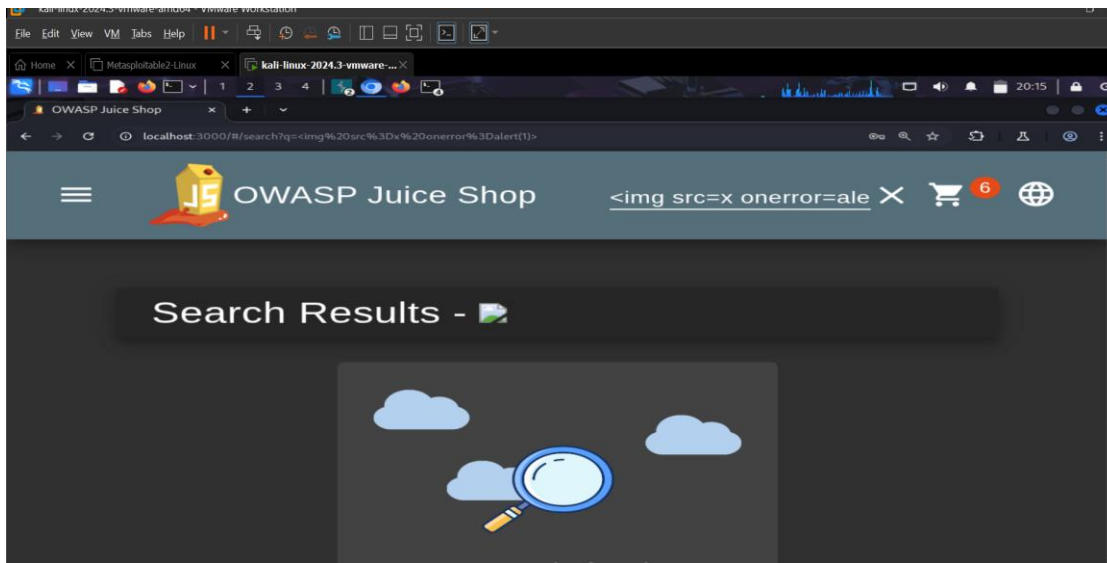


Figure: SQL Injection Evidence

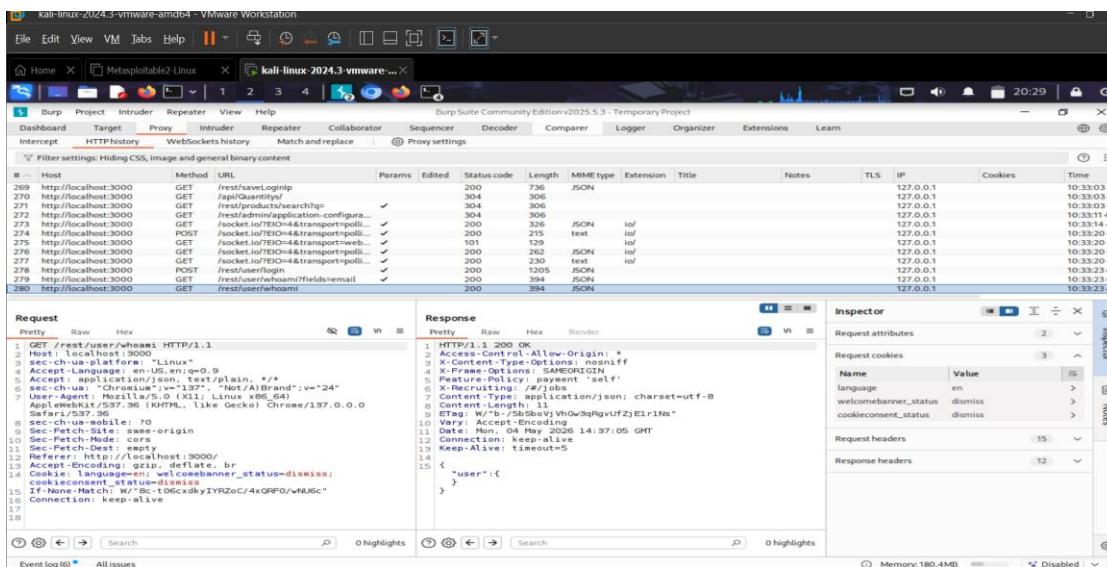


Figure: SQL Injection Evidence

2. Cross-Site Scripting (XSS)

Severity: High

Description: A reflected Cross-Site Scripting vulnerability was identified in the search functionality. JavaScript payload execution was successfully demonstrated.

Impact: Attackers may execute malicious scripts within victim browsers and hijack sessions.

Recommendation: Sanitize and encode user input before rendering.

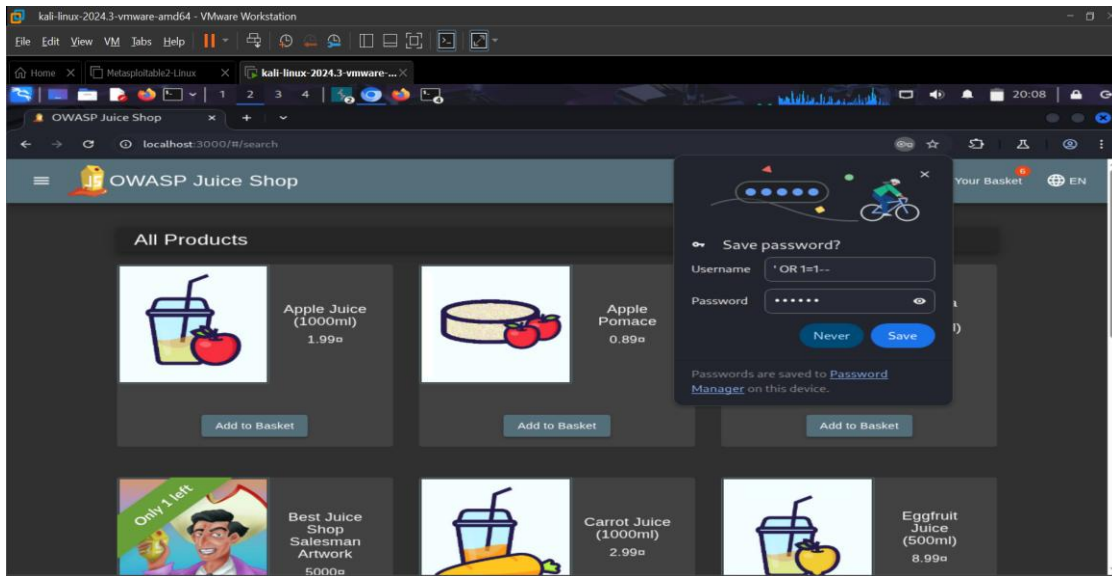


Figure: Cross-Site Scripting (XSS) Evidence

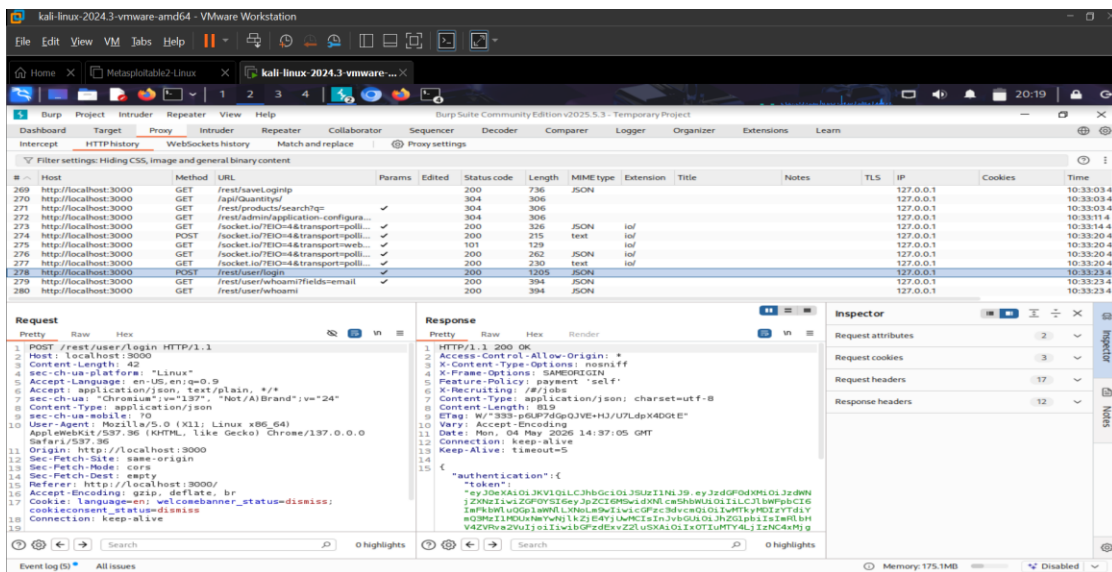


Figure: Cross-Site Scripting (XSS) Evidence

3. JWT Token Exposure

Severity: Medium

Description: JWT authentication tokens were exposed in intercepted HTTP responses after successful authentication.

Impact: Exposed JWT tokens may allow unauthorized session hijacking and account impersonation.

Recommendation: Use secure token handling mechanisms and HTTPS encryption.

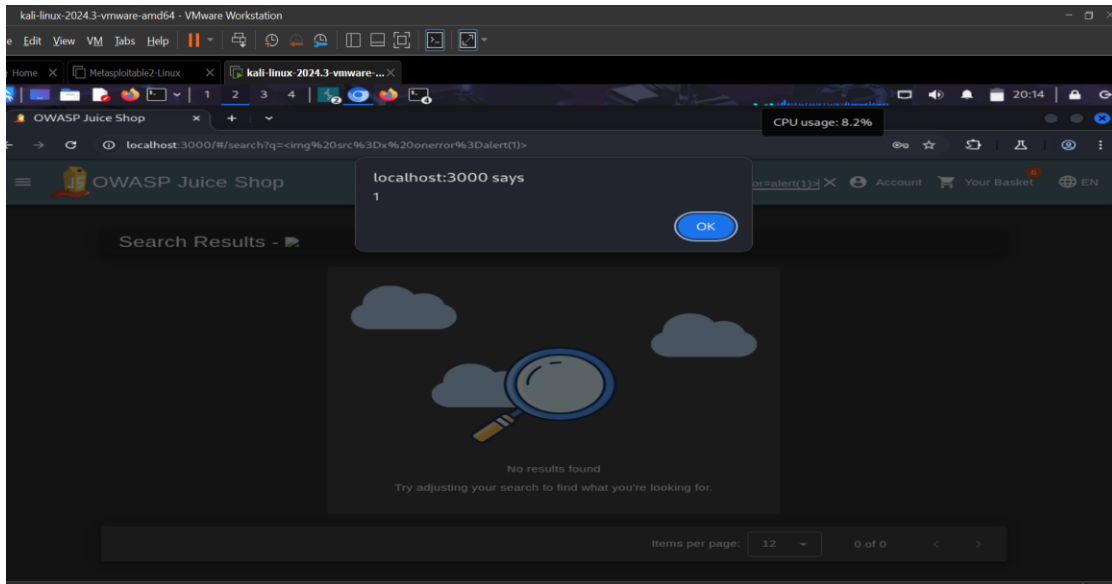


Figure: JWT Token Exposure Evidence

4. Sensitive Data Exposure

Severity: Medium

Description: Sensitive authentication-related information was visible in server responses during HTTP traffic analysis.

Impact: Attackers may gain access to confidential information useful for further attacks.

Recommendation: Minimize sensitive data exposure and secure communication channels.

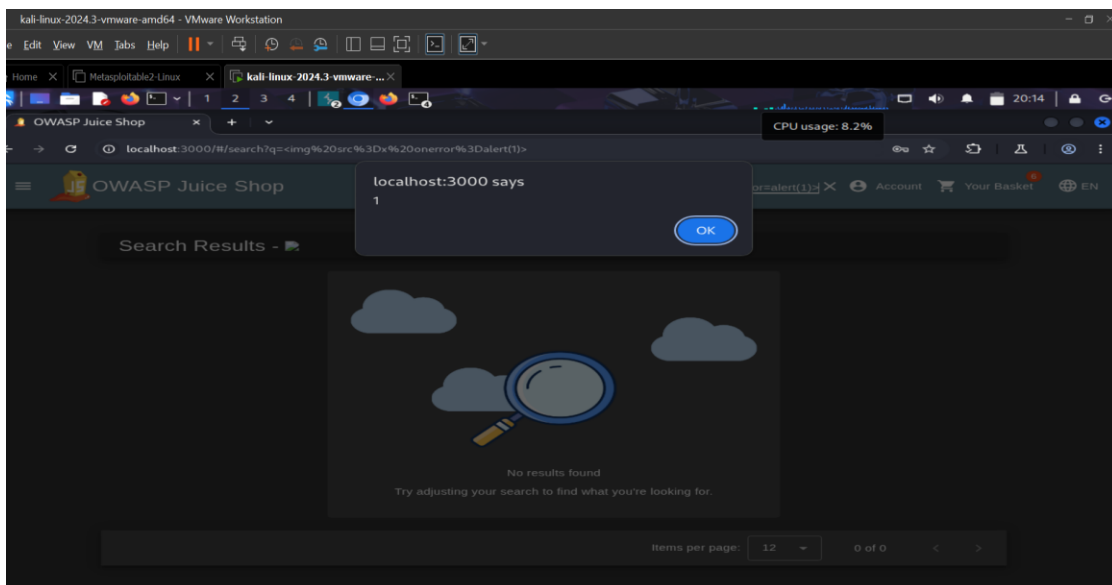


Figure: Sensitive Data Exposure Evidence

5. CORS Misconfiguration

Severity: Medium

Description: The application used a permissive CORS policy with Access-Control-Allow-Origin set to '*'.

Impact: Improper CORS configuration may allow unauthorized cross-origin requests.

Recommendation: Restrict allowed origins to trusted domains only.

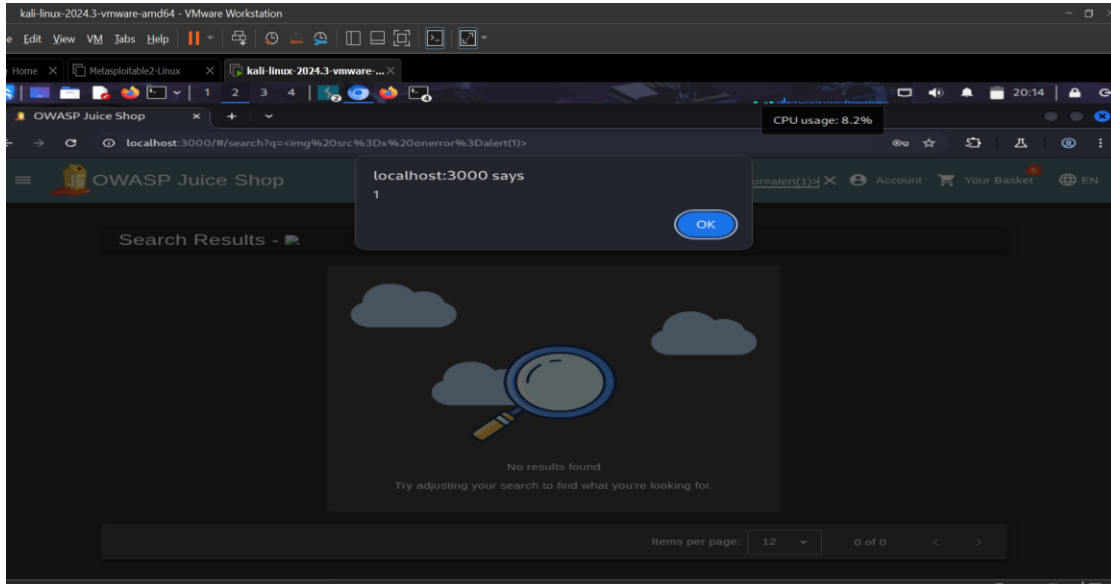


Figure: CORS Misconfiguration Evidence

Conclusion

The vulnerability assessment identified multiple security weaknesses within OWASP Juice Shop, including SQL Injection, Cross-Site Scripting, JWT Token Exposure, Sensitive Data Exposure, and CORS Misconfiguration. Proper input validation, secure authentication handling, and secure configuration practices are recommended to improve overall application security.

References

- OWASP Top 10
- OWASP Juice Shop Documentation
- Burp Suite Community Edition Documentation